PROJECT SENTINEL

Ransomware Canary & Early-Detection Platform

A production-oriented defensive security platform that continuously watches file-system activity, deploys decoy canary files, analyses entropy, correlates abnormal behaviour into a risk score, and runs an authorization-gated response.

100% detection **0% false positives** **~0.05s latency** **83 tests passing**

Technical Overview & Architecture

Version 1.0.0

Defensive tool: it never encrypts, deletes or damages data; the simulator runs only in a disposable sandbox.

Contents

1 **Executive Summary** — What SENTINEL is and why it exists

2 **System Architecture** — Agent, control plane, dashboard and data flow

3 **Detection Engine** — Entropy, canaries, behaviour, attribution, risk scoring

4 **Incident Response & Recovery** — Five response levels, approvals, evidence, snapshots

5 **Control Plane & Security Model** — Signing, authentication, RBAC, audit, hardening

6 **Real-Time Dashboard** — The eight SOC console pages

7 **Data Model & Retention** — Database tables and lifecycle

8 **Deployment** — Linux, Windows, macOS and Docker

9 **Testing, Simulator & Benchmarks** — Safe simulation and measured results

10 **Repository, Stack & Getting Started** — Layout, technology and how to run

11 **Acceptance Criteria** — How each requirement is met

This document describes the design, detection logic, response workflow, security model, deployment and measured performance of PROJECT SENTINEL. It is a defensive cybersecurity platform; it detects and contains ransomware behaviour and never encrypts or destroys user data.

1 Executive Summary

PROJECT SENTINEL is a locally deployable, enterprise-oriented platform that detects ransomware **before significant damage occurs**. A background agent observes the file system in real time, deploys realistic but harmless decoy files, measures file entropy, and correlates independent behavioural signals into a single risk score. When risk rises, a policy-driven response engine raises alerts, preserves forensic evidence and applies containment — with every high-impact action gated behind explicit authorization.

It is a functional product, not a prototype: the agent captures live filesystem telemetry, the detection engines run on real file content, incidents are persisted to a database, and a real-time dashboard shows actual backend data. The whole platform runs offline and continues protecting an endpoint with no network connectivity.

Design principles

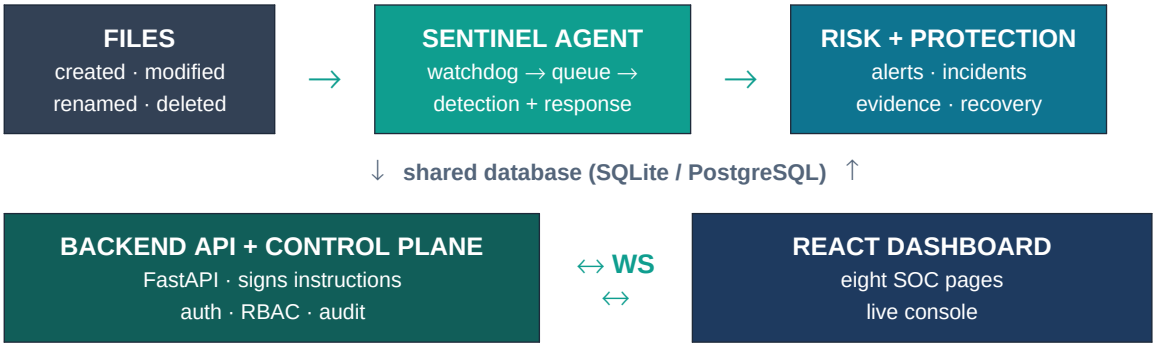
- **Defence in depth.** No single signal is decisive (except a canary hit). Independent signals corroborate each other, which is what makes detection both early and low-noise.
- **Low false positives.** Entropy is interpreted with file-type awareness, history deltas and header checks, so a compressed archive is never mistaken for an encrypted document.
- **Safety first.** The agent never auto-terminates arbitrary processes, never deletes suspicious files by default, and never modifies user data. Irreversible actions require approval.
- **Explainability.** Every risk score carries the exact list of contributing signals and the points each one added, so an analyst can see *why* the system is concerned.
- **Verifiable integrity.** The agent acts only on cryptographically signed instructions; actions and administrative changes are written to a tamper-evident audit log.

At a glance

Component	Summary
Endpoint agent	Python background service; threaded, non-blocking, self-healing
Detection	Canary + entropy + behaviour + process attribution, fused into a 0–100 risk score
Response	Five levels (observe → warn → protect → contain) + verified recovery
Control plane / API	FastAPI; signs agent instructions; Argon2id, JWT, RBAC, audit chain
Dashboard	React + TypeScript SOC console, eight pages, live over WebSocket
Storage	SQLite (single host) or PostgreSQL (enterprise)
Deployment	systemd, Windows Service, macOS launchd, Docker Compose

2 System Architecture

SENTINEL has three cooperating tiers that share one database. On a single host all three run locally; in an enterprise deployment many agents report to one control plane backed by PostgreSQL.



The endpoint agent

The agent is organised as a set of threads around a bounded event queue so that no slow operation ever blocks event capture:

- **Non-blocking capture.** The filesystem callback does minimal work and pushes to a bounded queue; under load it drops and counts events rather than stalling the OS notifier.
- **Coalescing de-duplication.** Repeated events for the same file within a short window are collapsed, so behavioural counters are not artificially inflated.
- **Asynchronous entropy.** Reading file content happens on a separate, rate-limited worker — never on the event path.
- **Batched persistence.** Telemetry is buffered and flushed in batches by a dedicated writer thread with retry and backpressure.
- **No feedback loops.** The agent's own storage and the files it writes (canary deployment) are excluded from monitoring.
- **Self-healing.** Worker loops restart with exponential backoff if they crash; the service integrates with the systemd watchdog.

Cross-platform monitoring uses the native notification API on each OS — inotify on Linux, ReadDirectoryChangesW on Windows and FSEvents on macOS — through a single abstraction, so the same detection logic runs everywhere.

3 Detection Engine

Four independent mechanisms feed one explainable risk score. The goal is early detection with a low false-positive rate.

3.1 Entropy analysis

Encrypted data has nearly maximal entropy — but so do ZIP, JPEG and MP4 files. A naïve "entropy > 7.5" rule therefore fires constantly. SENTINEL combines three ideas: a **file-type baseline** (high entropy is normal in a .zip, abnormal in a .txt or .docx), a **history delta** (a file that was structured and suddenly becomes random is the classic encryption signature), and a **structure / header check** (encryption destroys the magic bytes, so a .pdf without %PDF is suspicious whatever its entropy). Chunked analysis catches partial encryption, and an LRU cache avoids re-reading unchanged files.

3.2 Canary files

Canaries are realistic but entirely synthetic decoy files (for example *Financial_Records_Canary.xlsx*). No legitimate workflow touches them, so any interaction is a high-confidence signal. They are structurally valid for their type, are guaranteed to contain no real secrets, and are watched two ways: instantly on filesystem events, and by periodic hash verification that catches anything the OS notifier missed. Triggered canaries auto-regenerate.

3.3 Behavioural detection

Sliding time-windows over change events recognise the *shape* of a ransomware run — rapid mass modification, deletion across directories, suspicious extension changes, document replacement, ransom-note creation — plus an adaptive baseline that learns what is normal for each endpoint and flags deviations.

3.4 Process attribution

Most notification APIs do not reveal which process caused an event. Where privileged telemetry is unavailable, SENTINEL correlates disk-write bursts to the dominating process (labelled as a heuristic), and flags processes that modify many files or write at high rates. Critical OS processes are on a protected allow-list.

3.5 Risk scoring

Signals are fused into a 0–100 score. Each active signal contributes its weight once (repeats add only a small, capped increment), a correlation bonus is added when several distinct signals are active at once, and signals decay after a time-to-live so the score returns to normal once activity stops.

Signal	Weight	Note
Canary modified / deleted / renamed	50	Elevated
Ransom note created	30	
Rapid mass modification	20	
Suspicious process behaviour	20	
Entropy spike / header mismatch	15	
Mass deletion / file replacement	15	
Suspicious extension change	15	
Multiple distinct signals	+10 … +25	Correlation bonus

Risk levels: 0–19 Normal · 20–39 Low · 40–59 Elevated · 60–79 High · 80–100 Critical. All weights and thresholds are configurable through a signed policy.

4 Incident Response & Recovery

The response engine is deliberately conservative. Risk level maps to a response level through a configurable policy, and every high-impact or irreversible action requires explicit authorization, is audit-logged, and is reversible where technically possible.

Level	Risk	Actions
OBSERVE	Normal · Low	Record telemetry, update the risk score
WARN	Elevated	Desktop notification, dashboard event, preserve telemetry
PROTECT	High	Preserve evidence; write-protect affected directories; open an incident
CONTAIN	Critical	Preserve evidence; queue process suspension / isolation for approval
RECOVERY	On demand	Compare against verified snapshots and restore affected files

Approval workflow

Reversible actions (process *suspension*, directory write-protection) record rollback data and may run automatically only when explicitly configured. Irreversible actions (process termination, live network isolation) are always created as *pending approval* and execute only after an administrator approves them — delivered to the agent as a signed command the agent verifies before acting. Network isolation defaults to a dry run.

Evidence & recovery

- **Evidence vault.** Affected files are copied read-only into a tamper-evident vault with per-file SHA-256 hashes and an HMAC-signed manifest, bounded by file-count and byte budgets. Originals are never modified.
- **Verified snapshots.** Point-in-time backups carry a signed manifest; a snapshot is used for restore only after its signature and every file hash verify — a corrupted snapshot is refused.
- **Auditable restore.** Restore compares the live directory to a verified snapshot and reports exactly which files it changed; it is always an explicit, authorized action.

Safety guarantees. SENTINEL never automatically terminates arbitrary system processes, never deletes suspicious files as a default response, and never encrypts, overwrites or modifies user data — including during testing. Critical OS processes are protected, and evidence is preserved before any protective action.

5 Control Plane & Security Model

As a security product, SENTINEL's own trust boundaries matter as much as its detection logic.

Signed instructions

The backend is the **control plane**: it holds an Ed25519 private key and signs every instruction the agent will act on — which directories to monitor, response commands, and policy documents. The agent holds only the public key, so a process that can write to the database, or even the agent host itself, cannot forge instructions. Unsigned or badly-signed rows are rejected and raise a configuration tamper signal.

Authentication & access control

- **Passwords:** Argon2id hashing with automatic rehash on parameter changes.
- **Tokens:** short-lived JWT access tokens plus refresh tokens that rotate on every use; reuse of a spent refresh token is treated as theft and revokes the whole session family.
- **Roles:** viewer (read), analyst (operate), admin (approve containment, publish policy, manage users) — enforced on every endpoint.
- **Lockout & rate limiting:** failed-login lockout and per-IP token-bucket limits; the WebSocket requires a valid token.

Hardening & integrity

- Strict security headers and a restrictive Content-Security-Policy on every response.
- Secrets stored with 0600 permissions in a 0700 directory and never committed to version control.
- A tamper-evident, hash-chained audit log; a verification endpoint detects any insertion, deletion or modification. Failed logins and token-reuse are recorded even when the request fails.
- Least-privilege execution; hardened systemd sandboxing; the Docker image runs as a non-root user.

6 Real-Time Dashboard

A dark, SOC-styled console (React + TypeScript + Vite + Tailwind + Recharts) renders entirely from live backend data, with a WebSocket feed for real-time updates. The built bundle is served directly by the API.

Page	Contents
Command Center	Security posture, risk gauge, threat-activity timeline, recent alerts/incidents
File Intelligence	Monitored directories, file-type distribution, entropy changes, recent events
Canary Management	Canary inventory and status; deploy, verify and regenerate controls
Process Intelligence	Running processes, file-modification attribution, suspicious processes
Threat Detection	Alert triage with per-signal risk breakdown and false-positive feedback
Incident Response	Incident timeline, affected files/processes, action approval and rollback
Forensics	Evidence vault and the audit log with live chain verification
Settings	Monitored directories, signed policy editor, and user administration

Access is role-aware: viewers see read-only data, analysts operate the platform, and only administrators can approve containment, publish policy or manage users.

7 Data Model & Retention

The schema (SQLAlchemy models with Alembic migrations) is shared by the agent and the API and runs on both SQLite and PostgreSQL. Key tables:

Tables	Purpose
endpoints, monitored_directories	Registered agents and the signed directories they watch
file_events, file_inventory	Raw filesystem telemetry and the current known-file set
entropy_history	Per-file entropy measurements, deltas and verdicts
canary_files	Canary state, hashes, interaction history and generation
processes	Process telemetry and suspicion status
incidents, security_alerts	Correlated incidents and the alerts attached to them
response_actions, evidence_items	Response lifecycle (with rollback) and preserved evidence
snapshots	Backup snapshots with signed manifests
agent_commands, system_configuration	Signed commands and signed policy versions
users, refresh_tokens, audit_logs	Identity, sessions and the tamper-evident audit chain

A retention runner periodically purges aged, low-value telemetry (file events, entropy history, exited processes, completed commands) while preserving incidents, evidence and resolved alerts far longer. Horizons are configurable.

8 Deployment

SENTINEL ships deployment artifacts for every major platform. The agent runs as a boot-time background service and restarts automatically on failure.

Platform	Mechanism
Linux	systemd units (agent + API) with strong sandboxing and watchdog; installer with a dedicated service account
Windows	Windows Service wrapper (pywin32) and a PowerShell installer
macOS	launchd daemon plist
Docker	Multi-stage image (builds the dashboard, runs as non-root) and Docker Compose with an optional PostgreSQL service

Configuration

A single YAML file holds bootstrap settings (data directory, database URL, intervals) and the default detection policy. The bootstrap section is read only from the file or environment; all detection and response parameters can be overridden at runtime by a signed policy published from the dashboard, which the agent verifies before applying.

Quick start (local)

```
python3 -m venv .venv && source .venv/bin/activate
pip install -r requirements.txt
python -m agent init && python -m backend init-keys
python -m backend create-user admin admin@example.com --role admin
cd frontend && npm install && npm run build && cd ..
python -m backend run # dashboard + control plane on :8443
python -m agent run # the detection agent
```

9 Testing, Simulator & Benchmarks

A safe simulator reproduces ransomware **behaviour** — mass modification, extension renaming, encrypt-and-replace, mass deletion, ransom notes and canary tampering — without any real malware. It operates **only inside a disposable sandbox it creates and marks**, refuses any directory lacking that marker, and rejects protected locations and path escapes, so it can never touch real data.

A benchmark harness runs the agent against these scenarios and measures detection rate, false-positive rate, latency, CPU/memory, throughput and canary reliability, producing a reproducible report. A representative run:

Metric	Result
Detection rate (malicious scenarios)	100%
False-positive rate (benign activity)	0%
Mean detection latency	~0.05 s
Canary detection reliability	100%
Automated test suite	83 tests passing (unit + integration)

Exact figures vary with hardware and thresholds; the benchmark is reproducible with *python -m simulator benchmark*. The suite covers entropy maths, canary logic, behavioural detectors, risk scoring, signing, the evidence vault and snapshots, the full protection pipeline (alert → incident → approval → execute → rollback), the API (auth rotation/reuse/lockout, RBAC, signing, policy validation), agent restart/resume and offline operation.

10 Repository, Stack & Getting Started

Repository layout

```
agent/ endpoint agent (filesystem, entropy, canary, behaviour, detection,
            response, telemetry, service)
backend/ FastAPI control plane + API, auth, models, migrations, services, websocket
frontend/ React + TypeScript + Vite + Tailwind dashboard (eight pages)
simulator/ safe, sandbox-only ransomware simulator + benchmark harness
tests/ unit + integration tests
deployment/ windows / linux / docker / macos artifacts
docs/ documentation + benchmark reports
config/ default configuration
```

Technology stack

Area	Technologies
Agent & backend	Python 3.12+, FastAPI, SQLAlchemy, Alembic, watchdog, psutil, NumPy, cryptography, Argon2id, PyJWT, Pydantic
Frontend	React 18, TypeScript, Vite, Tailwind CSS, Recharts, lucide-react
Data & comms	SQLite / PostgreSQL, WebSockets, JSON, structured logging
Security	Ed25519 signing, Argon2id, RBAC, HMAC manifests, hash-chained audit log, TLS

Try a safe simulation

```
python -m simulator attack # runs entirely in a disposable sandbox
python -m simulator benchmark # measures detection, latency and false positives
```

Everything runs offline; the documentation set in *docs/* covers architecture, installation, per-platform deployment, the API, the database schema, the detection engine, incident response, the security model, testing and troubleshooting.

11 Acceptance Criteria

The platform satisfies each of its acceptance requirements, verified by tests:

Requirement	Met
Background service independent of the dashboard	✓
Filesystem events captured in real time	✓
Entropy calculated on real test files	✓
Canary files deployed and monitored	✓
Unauthorized canary changes generate alerts	✓
Behavioural detection of mass-modification	✓
Risk scoring combines multiple signals	✓
Incidents persisted in the database	✓
Dashboard displays real backend telemetry	✓
Response actions follow authorization policy	✓

Requirement	Met
Works offline	✓
Tests demonstrate detection performance	✓
Installation and deployment documented	✓
No critical functionality replaced by mock data	✓
Starts reliably after a reboot (restart/resume)	✓

PROJECT SENTINEL is a genuine defensive cybersecurity platform with an operational background agent, reliable and explainable detection logic, a safe and authorized response workflow, and a fully integrated real-time dashboard.